

Rapport Technique

Nisrine School

Sprint Sécurité & Fonctionnalités — 18–19 Mai 2026

Rédigé par : Zayd Dahhaoui

✓ DÉPLOYÉ SUR VERCEL

SPRINT TERMINÉ

Dépôt privé GitHub :
Zayddahhaoui0609/ns

17

FIXES & FEATURES

4

FAUX POSITIFS IDENTIFIÉS

2

JOURS DE SPRINT

2

REPOS GITHUB SYNCHRONISÉS



18 MAI 2026 — SÉCURITÉ & CORRECTIFS

1 En-têtes de sécurité HTTP ajoutés

HSTS (1 an), CSP, X-Content-Type-Options, X-XSS-Protection, Referrer-Policy, Permissions-Policy, X-Frame-Options: SAMEORIGIN

`server.js`

SÉCURITÉ

2 Formulaire public → "Demande d'inscription" (CIN supprimé)

Champ CIN et téléphone du parent retirés — données sensibles inutiles au stade de la demande

`register.html` `routes/registration.js`

SÉCURITÉ

3 Dossier `/uploads/` protégé par authentification JWT

Middleware JWT ajouté sur la route statique `/uploads/` — empêche l'accès non authentifié aux fichiers uploadés

`server.js`

SÉCURITÉ

5 Bug spinner "Chargement des avis..." corrigé

Timeout AbortController de 8s ajouté sur le fetch ratings — évite le spinner infini lors d'un cold start Vercel

`js/ratings.js` `index.html`

BUG UX

6-11 Autres correctifs UI/Légaux

MULTI

Compteur "Dreams Achieved" corrigé (threshold IntersectionObserver 0.5→0.1) · Email obfusqué dans le HTML · Pages légales créées (Privacy Policy + CGU, 4 langues) · Bannière consentement cookies RGPD · Rate limiting (express-rate-limit) · Sanitisation NoSQL (mongo-sanitize)

[js/main.js](#) [index.html](#) [privacy-policy.html](#) [terms.html](#) [server.js](#)

📅 19 MAI 2026 — 2FA · CAPTCHA · 404 · PROD FIXES

12 2FA par Email OTP pour les comptes admin

SÉCURITÉ

Code à 6 chiffres envoyé sur l'email personnel de chaque admin · Expiry 5 min · Temp JWT pour la session 2FA · Bypass dev/super-admin · 6 nouveaux endpoints API · Interface admin (saisie OTP, renvoi, activation/désactivation)

[models/Admin.js](#) [routes/admin.js](#) [services/emailService.js](#) [admin.html](#) [js/admin-dashboard.js](#)

13 Protection CAPTCHA reCAPTCHA v3 sur tous les formulaires publics

SÉCURITÉ

Middleware verifyCaptcha créé · Score seuil 0.5 · Fail-open (si Google injoignable) · Dev-skip si clé absente · Appliqué sur : contact, rating, inscription, CV, traduction, candidature emploi

[middleware/captchaMiddleware.js](#) [routes/contact.js](#) [routes/ratings.js](#) [routes/registration.js](#) [routes/services.js](#)
[routes/jobApplications.js](#)

14 Bug formulaire rendez-vous : champ nom bloqué après le premier ajout

BUG UX

Cause : alert() natif vole le focus et l'OS ne le restaure pas · Fix : setTimeout 100ms qui remet le focus sur fullNameInput à l'ouverture du modal

[js/appointments.js](#) → [openAddAppointmentModal\(\)](#)

15 Correction 2FA en production Vercel (fire-and-forget tué par serverless)

CRITIQUE

Cause 1 : Vercel coupe la fonction serverless dès que res.json() est appelé — la promesse email en arrière-plan n'est jamais résolue → email jamais envoyé en prod

Fix 1 : await emailService.send2FACode() avant la réponse HTTP

Cause 2 : Expiry 5 min trop court avec le cold-start Vercel + délai SMTP

Fix 2 : Expiry porté à 10 minutes (code + JWT temp)

[routes/admin.js](#) — POST /api/admin/login POST /api/admin/2fa/resend

16 Page 404 personnalisée (thème marocain, auto-traduite)

FEATURE UX

Design inspiré de la référence · Image réelle Door.png (floating) · Feuilles Leaf.png floues · Avion en papier animé · Signposts sombres avec FA icons · Boutons gradient rouge-orange · Lien WhatsApp · Traduction auto DE/FR/EN/AR via localStorage · Images commitées dans git (n'étaient pas trackées)

17 Onglet Paramètres visible pour tous les rôles admin

UX

Les employés peuvent désormais accéder à la section 2FA dans Paramètres · Les sections "changer username/mot de passe" restent masquées pour les employés (super_admin uniquement)

js/admin-dashboard.js admin.html

⚠ FAUX POSITIFS DU DIAGNOSTIC INITIAL



FP-1 · "Injection SQL détectée sur les endpoints API"

Le backend utilise MongoDB + Mongoose ODM — aucune base SQL. OWASP ZAP envoie des payloads SQL génériques (' OR 1=1 --) sur tous les endpoints sans connaître la stack backend. Mongoose avec typage implicite protège contre les injections NoSQL. **Action préventive** : mongo-sanitize ajouté (fix #10) malgré le faux positif.

FAUX POSITIF — ZAP sans contexte stack



FP-2 · "Paramètre ?cin= visible dans les URLs"

Le CIN n'a jamais été envoyé en GET — uniquement via POST body (FormData). Aucune route backend n'utilise req.query.cin ni req.params.cin. Le diagnostic a probablement confondu les valeurs CIN affichées dans le DOM du tableau admin avec une exposition URL. **Action préventive** : CIN retiré du formulaire public (fix #2).

FAUX POSITIF — Confusion DOM vs URL param



FP-3 · "Photos étudiants dans /img/ sans contrôle d'accès"

Le dossier /img/ contient uniquement des assets du site (logo, images services, motifs zéliges). Zéro photo d'étudiant. Les vraies photos sont stockées dans Mega.nz (via megajs) ou en base64 dans MongoDB, servies via des endpoints authentifiés. **Action ciblée** : /uploads/ protégé par JWT (fix #3) — c'est le vrai vecteur de risque.

FAUX POSITIF — Mauvais dossier ciblé



FP-4 · "2ème certificat SSL non fiable (no-sni.vercel-infra.com)"

Comportement standard de l'infrastructure Vercel. Quand un client se connecte sans SNI (Server Name Indication), Vercel retourne son certificat par défaut. Tous les navigateurs modernes supportent SNI. Aucune action nécessaire.

NON-BUG — Infrastructure Vercel standard



FP-5 · "Codes 2FA incorrects / reçus trop tard en production"

Ce n'était pas un bug de logique. Deux causes réelles identifiées : (1) Vercel tue les tâches en arrière-plan après `res.json()` → email jamais envoyé en prod. (2) L'utilisateur lisait d'anciens emails (codes précédents) et non le dernier code généré. Résolu par fix #15 (await email + expiry 10 min).

MALENTENDU — Cause serverless + confusion email

CHRONOLOGIE DU SPRINT



18 Mai — Matin

En-têtes sécurité · CIN supprimé · /uploads/ protégé



18 Mai — Après-midi

Email obfusqué · Pages légales · Cookie consent



18 Mai — Soir

Rate limiting · mongo-sanitize · Correctifs UI (spinner, compteur)



19 Mai — Matin

2FA Email OTP complet (backend + frontend + UX)



19 Mai — Après-midi

reCAPTCHA v3 sur tous les formulaires publics · Push GitHub × 2 repos



19 Mai — Soir (~21h)

Fix bug rendez-vous · Fix 2FA prod (await + expiry) · Page 404 marocaine · Images git

Rapport généré le 19 Mai 2026 à 21h05 (UTC+2)

Stack : HTML · CSS · JavaScript (Vanilla) → Node.js · Express.js → MongoDB Atlas (Mongoose) → Vercel Serverless · Socket.io · JWT · Nodemailer · reCAPTCHA v3